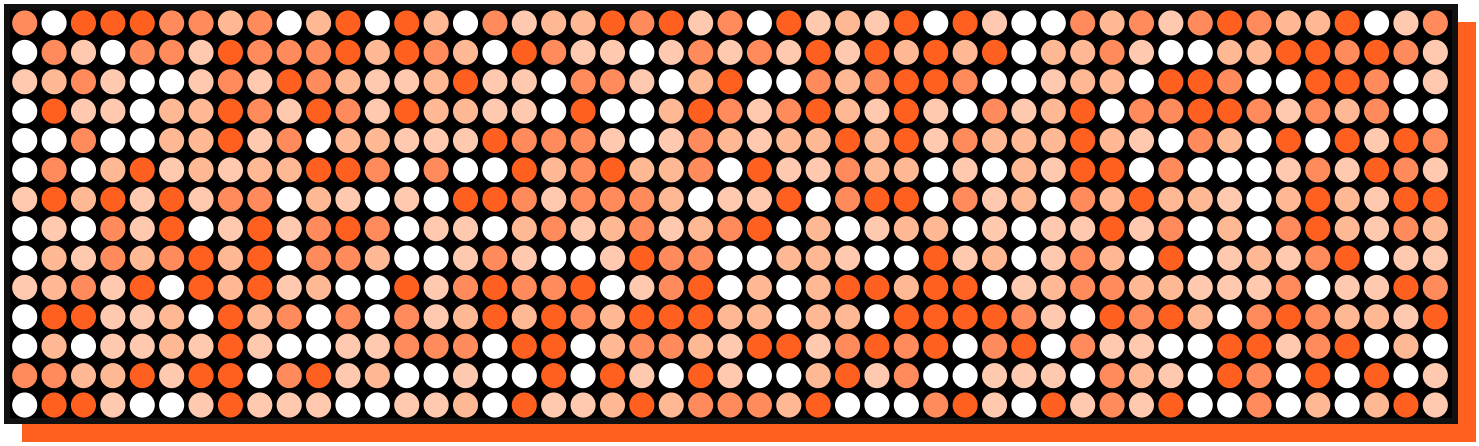
PAPYRUS EVIDENCE PACK

SECURITY CONTROLS MATRIX

Authentication, RBAC, encryption, isolation, auditing, secrets handling and known gaps, mapped to NIST SP 800-53 Rev. 5.



RELEASE	BUILT
0.1.0+3e23d44	2026-10-27T15:00:32Z
IMAGE	**INDEX DIGEST**
ghcr.io/beaglabs/papyrus/papyrus	sha256:d399de55560bdac84b62c098284781fd4910d3396834ca2629ebdfaa2dd0f86d

Prepared by Beag Labs from the Papyrus source and its published release image. Describes the software and the responsibilities it leaves to a deploying organization. It is not a certification, an authorization or a third-party assessment.

SECURITY CONTROLS MATRIX

How Papyrus contributes to NIST SP 800-53 Rev. 5 controls when a customer deploys it, and what remains with the deploying organization. Controls were reviewed against Papyrus source revision `3e23d4432d3e`. The release image was built from `3e23d4432d3e`.

26	22	0	2
IMPLEMENTED	PARTIAL	PLANNED	CUSTOMER OWNED

Reading this matrix. *Implemented* means Papyrus code enforces the behavior described; *partial* and *planned* items have an open entry in the known gaps plan. *Responsibility* shows whether Papyrus (provider), the deploying organization (customer) or both (shared) carry the control. The machine-readable form is `oscal/papyrus-component-definition.json`; source evidence paths for every row are in `papyrus-controls-matrix.xlsx`.

ACCESS CONTROL

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
AC-2 Account Management	PARTIAL shared	Papyrus creates no local user accounts or passwords; every person is an identity from the organization's OpenID Connect provider or Microsoft Entra ID, configured in papyrus.yaml, and authority comes only from the declared Papyrus roles, from token or directory-group claims mapped in papyrus.yaml, or from Papyrus role assignments. There is no first-run setup page: the first System Owners are named in papyrus.yaml (identity.owners) and receive the role when they first sign in. Only a System Owner (never an API key) can grant or revoke roles, the last System Owner cannot be revoked, and every grant and revocation is written to an append-only event table. With SCIM 2.0 provisioning on, a person the directory deprovisions or deactivates loses access on their next request. Automation uses API keys: service identities with no roles that name the workflows they may run and expire after 1 to 365 days (default 90). Evidence: `apps/server/src/agent/auth.ts`, `apps/server/src/agent/role-assignments.ts`, `apps/server/src/agent/config.ts`, `apps/server/src/agent/api-keys.ts` Tests: `apps/server/tests/agent-auth.test.ts`, `apps/server/tests/api-keys.test.ts`, `apps/server/tests/agent-role-assignments.test.ts`	Own the account lifecycle in the identity provider (proofing, approval, periodic review, removal), name the first System Owners in papyrus.yaml, and review Papyrus role assignments and API keys on the organization's cadence.
AC-3 Access Enforcement	PARTIAL provider	Every protected HTTP route authenticates the caller server-side and rejects principals that hold no Papyrus role; administrative, integration, approval, audit and owner-only operations check the specific role on the server before acting. Until a System Owner accepts the current Terms of Service and Privacy Policy in the app, only sign-in, the terms and health routes answer. MCP servers, imported APIs and API keys are scoped to the caller's tenant, and an API key is admitted only to start runs of the workflows it names and read the runs it started. Named agents run only from an active, signed revision; within a session an agent may use any tool the deployment offers, and whether a tool call needs a person's approval is decided by the tool's permission policy and, for MCP tools, the administrator's classification. Evidence: `apps/server/src/agent/http.ts`, `apps/server/src/agent/roster/store.ts`, `apps/server/src/agent/mastra/native-runtime.ts` Tests: `apps/server/tests/agent-integrations.test.ts`, `apps/server/tests/agent-observability.test.ts`, `apps/server/tests/agent-api-keys-http.test.ts`, `apps/server/tests/agent-mcp-http.test.ts`	Assign Papyrus roles in Entra according to organizational need-to-know.

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
AC-4 Information Flow Enforcement	PARTIAL shared	Papyrus enforces fixed flow rules in code: agent workspace commands run with network access denied; repository imports and package installs are downloaded by the server, never the sandbox, and nothing in them runs; credentials are resolved by trusted runtime code and never passed to models or workspace processes; MCP tool results are labeled as external content. Outbound requests made for workflow HTTP steps, link previews, MCP servers and repository imports pass an egress gate: with egress.allowedHosts set in papyrus.yaml only listed hosts (names or *.suffix) are reached, and on the disconnected profile nothing outside the boundary is reached until it is listed. Evidence: `apps/server/src/agent/egress.ts`, `apps/server/src/agent/mastra/workflow-runtime-tools.ts`, `apps/server/src/agent/mastra/fetch-preview.ts`, `apps/server/src/agent/mcp/connect.ts`, `apps/server/src/agent/repository-import.ts` Tests: `apps/server/tests/agent-egress.test.ts`, `apps/server/tests/agent-repository-import.test.ts`	Set PAPYRUS_WORKFLOW_HTTP_DENYLIST and PAPYRUS_WORKFLOW_HTTP_INTERNAL_HOSTS to match the authorization boundary, and enforce egress policy at the network layer.
AC-5 Separation of Duties	PARTIAL shared	The agent can propose but cannot approve: approveProposal, denyProposal and executeAction are rejected at the agent tool layer, and approval routes require a human Entra session holding Papyrus.Action.Approve. Workflow approval steps addressed to a person or group can be answered only by that person, a member of that group, or a System Owner, never by the person who started the run. Authority-weakening policy changes wait for a Governance principal (System Owner, or Security.Manage plus Action.Approve). Evidence: `apps/server/src/agent/mastra/tools.ts`, `apps/server/src/agent/workflow-approval.ts`, `apps/server/src/agent/policies/store.ts`, `apps/server/src/agent/service.ts` Tests: `apps/server/tests/security-invariants.test.ts`, `apps/server/tests/workflow-approval.test.ts`	Assign Papyrus.Action.Approve, Papyrus.Security.Manage and Papyrus.System.Owner to different people according to organizational separation-of-duties policy.
AC-6 Least Privilege	PARTIAL shared	Papyrus splits authority into roles (integration view and manage, security manage, action approve, audit view and system owner) and checks the narrowest one per operation; Papyrus.System.Owner implies all of them. API keys hold no roles. The container runs as a non-root user, and workspace commands run with the data directory unreadable and network denied. Evidence: `packages/contracts/src/index.ts`, `apps/server/src/agent/auth.ts`, `apps/server/src/agent/entra-app-setup.ts`, `Dockerfile` Tests: `apps/server/tests/agent-auth.test.ts`	Grant the narrowest role that fits each person, limit System Owner assignments, and do not run the container privileged.
AC-7 Unsuccessful Logon Attempts	IMPLEMENTED shared	Papyrus accepts no passwords, so interactive logon attempts and lockout are handled by the identity provider. Every completed and failed sign-in callback is written to the audit trail with the client address. Workflow webhook secrets are 256 random bits made by the server, and invalid, expired, revoked and rotated API keys all receive the same 401. Evidence: `apps/server/src/agent/http.ts`, `apps/server/src/agent/api-keys.ts` Tests: `apps/server/tests/agent-workflow-webhook-http.test.ts`, `apps/server/tests/agent-api-keys-http.test.ts`	Configure Entra smart lockout, Conditional Access and sign-in risk policies for the tenant.
AC-8 System Use Notification	IMPLEMENTED shared	With security.notice set in papyrus.yaml, Papyrus shows the system use notice before sign-in (dow for the standard DoD notice and consent banner, or the organization's own text from a file) and starts sign-in only after the person consents. Each acknowledgement is recorded in the audit trail with the notice's digest and the client address. Evidence: `apps/server/src/agent/http.ts`, `apps/web/src/App.tsx`	Choose the notice text approved for the system and set security.notice.
AC-10 Concurrent Session Control	IMPLEMENTED provider	Each person may hold at most three portal sessions at once by default (security.sessions.concurrent); a new sign-in ends the oldest beyond the limit. Evidence: `apps/server/src/agent/portal-sessions.ts` Tests: `apps/server/tests/agent-portal-sessions.test.ts`	Set the limit the organization requires.

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
AC-11 Device Lock	IMPLEMENTED shared	After 15 minutes without activity (security.sessions.idleMinutes) the portal signs the person out and returns to the sign-in screen, and the server ends the session independently, so an unattended browser requires re-authentication through the identity provider. Evidence: `apps/web/src/App.tsx`, `apps/server/src/agent/portal-sessions.ts` Tests: `apps/server/tests/agent-portal-sessions.test.ts`	Apply operating-system screen locks on endpoints.
AC-12 Session Termination	IMPLEMENTED shared	Portal sessions are recorded on the server. Each sign-in opens a session that ends after 15 minutes without activity, after 12 hours however active it is, or on sign-out, which ends it on the server so a copied cookie stops working (security.sessions in papyrus.yaml sets the limits). The signed cookie carries only the session identifier and identity; each request is checked against the session record, and ending a session is audited. Evidence: `apps/server/src/agent/portal-sessions.ts`, `apps/server/src/agent/auth.ts` Tests: `apps/server/tests/agent-portal-sessions.test.ts`	Set identity-provider token lifetimes and sign-in frequency; choose session limits in papyrus.yaml that meet the organization's policy.
AC-16 Security and Privacy Attributes	PARTIAL shared	With security.classification set in papyrus.yaml, every screen, including sign-in and the Terms page, carries the system-high classification banner at the top in the standard colours (UNCLASSIFIED through TOP SECRET//SCI). Evidence: `apps/server/src/agent/http.ts`, `apps/web/src/App.tsx`, `packages/contracts/src/index.ts`	Set the system-high classification; apply marking to documents and media under the organization's marking policy.

AUDIT AND ACCOUNTABILITY

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
AU-2 Event Logging	PARTIAL shared	Papyrus writes one append-only audit trail of security events: successful and failed sign-ins, sign-outs, sessions ended for inactivity or age, acknowledgement of the system use notice, every refused request (401 and 403) with its route, acceptance of the Terms, and audit export tests. Separate append-only records cover role grants and revocations, every MCP tool call and MCP administrative change, API key lifecycle, policy decisions, configuration at each start, integration and action-ledger events, and agent signatures and evidence. Evidence: `apps/server/src/agent/audit/log.ts`, `apps/server/src/agent/http.ts`, `apps/server/src/agent/auth.ts`, `apps/server/src/agent/mcp/calls.ts` Tests: `apps/server/tests/agent-integrations.test.ts`, `apps/server/tests/agent-mcp-stores.test.ts`	Decide which additional events the organization requires and collect Entra sign-in logs from Microsoft.
AU-3 Content of Audit Records	IMPLEMENTED provider	Unified audit records carry a sequence number, an ISO 8601 UTC time, the action, the outcome (success, failure or denied), the actor and the person an agent acted for, the target, the client network address, user agent, request ID and session ID, and event detail without secrets or document content. MCP call records add session, workflow, tool classification, approval ID, duration and a SHA-256 of the arguments. Evidence: `apps/server/src/agent/audit/log.ts` Tests: `apps/server/tests/agent-local-secrets.test.ts`	
AU-4 Audit Log Storage Capacity	PARTIAL shared	Audit records are kept in the Papyrus data directory and, when audit.otlp is configured, delivered to the organization's collector; records written while the collector is unreachable are sent when it returns, and the backlog is shown on the Audit page. Evidence: `apps/server/src/agent/audit/otlp.ts`	Size the data volume and the collector's storage for the retention period the organization requires.
AU-6 Audit Record Review, Analysis, and Reporting	IMPLEMENTED shared	System Owners and Audit Viewers review the trail on the Audit page: search by person or action, filter by outcome and time range, read each record in full, and export the filtered list as CSV or JSONL. The same records are sent to the organization's OpenTelemetry collector (OTLP/HTTP, with optional CA and mutual TLS) for review in its SIEM, at least once, resuming after an outage; the page shows the export's health and can send a test record. Evidence: `apps/server/src/agent/audit/otlp.ts`, `apps/web/src/Audit.tsx`, `apps/server/src/agent/http.ts` Tests: `apps/server/tests/agent-audit-otlp.test.ts`	Set review cadence, alerting and escalation, and correlate Papyrus records with Entra and host logs in the organization's monitoring system.

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
AU-8 Time Stamps	IMPLEMENTED shared	Papyrus writes audit timestamps as ISO 8601 UTC strings taken from the host clock. Evidence: `apps/server/src/agent/role-assignments.ts`, `apps/server/src/agent/mcp/calls.ts`	Synchronize the host clock to an authoritative time source.
AU-9 Protection of Audit Information	PARTIAL shared	Audit tables are append-only at the database layer: triggers abort UPDATE and DELETE on the unified audit trail and on role, configuration, MCP, integration and model event tables; integration and action-ledger events are additionally SHA-256 hash-chained. With OTLP export configured, every record is also held by a collector outside the Papyrus host. Evidence: `apps/server/src/agent/database.ts`, `apps/server/src/agent/mcp/calls.ts`, `docs/security.md` Tests: `apps/server/tests/agent-integrations.test.ts`, `apps/server/tests/agent-smoke.test.ts`	Restrict host and database-file access, protect backups, and copy audit records to independently controlled immutable storage.
AU-12 Audit Record Generation	IMPLEMENTED provider	Audit records are generated server-side at the enforcement points themselves: the proposal approval and denial paths, the single MCP call path, role assignment changes, API key management and policy enforcement. They are therefore produced the same way regardless of which client made the request. Evidence: `apps/server/src/agent/service.ts`, `apps/server/src/agent/mcp/calls.ts`, `apps/server/src/agent/policies/store.ts` Tests: `apps/server/tests/agent-integrations.test.ts`	

CONFIGURATION MANAGEMENT

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
CM-2 Baseline Configuration	PARTIAL shared	Papyrus ships one container image: Amazon Linux 2023 minimal with OpenSSL's certified FIPS provider forced on, running as a non-root user with no browser engine, scanned in CI against the DISA STIG profile for Amazon Linux 2023. Runtime configuration comes from papyrus.yaml, a reviewable file in which secrets appear only as file or environment references, and its digest and effective settings are recorded at every start. Three deployment profiles (commercial, government, disconnected) set network posture. Evidence: `Dockerfile`, `deploy/marketplace/vm/provision.sh`, `docs/deployment.md` Tests: `apps/server/tests/agent-image-and-catalog.test.ts`	Document the approved deployment configuration: host OS, network, Entra registration, model endpoint, storage and the Papyrus image digest.
CM-3 Configuration Change Control	IMPLEMENTED shared	In-application changes that weaken policy become digest-checked governed changes that apply only after a Governance principal approves them, and an approval is refused if the change's digest or expected version no longer matches. Papyrus software updates are announced by exact image digest from an allowed repository and installed only when a System Owner applies them or within an owner-configured maintenance window. Evidence: `apps/server/src/agent/policies/store.ts`, `apps/server/src/agent/updates/service.ts`, `apps/server/src/agent/policies/http.ts` Tests: `apps/server/tests/agent-policies.test.ts`, `apps/server/tests/agent-updates.test.ts`, `apps/server/tests/agent-policies-http.test.ts`	Operate organizational change control for deployment configuration, infrastructure and when updates are applied.
CM-5 Access Restrictions for Change	IMPLEMENTED shared	Configuration endpoints require specific roles on the server: Integration.Manage for model gateways, MCP servers, imported APIs, package mirrors, browser and mainframe settings and branding; System Owner for role assignments, updates, license activation and skill approval; Governance for governed changes. Model API keys are accepted only over HTTPS from the portal origin. Evidence: `apps/server/src/agent/http.ts`, `apps/server/src/agent/policies/store.ts` Tests: `apps/server/tests/agent-updates.test.ts`	Control access to the host, container runtime, data directory, secret stores and deployment pipeline.

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
CM-6 Configuration Settings	IMPLEMENTED shared	Configuration is validated at startup and fails closed: papyrus.yaml is checked against its schema (unknown keys and bad values stop startup), an identity provider is required, persistent mode requires an HTTPS public origin, the license named in license.file must verify for this deployment, and the former development and license bypasses are refused. Every start records which file was used, its digest and each effective setting with where it came from, and flags a change from the previous start. Evidence: `apps/server/src/agent/config-file.ts`, `apps/server/src/agent/config-audit.ts`, `apps/server/src/index.ts` Tests: `apps/server/tests/agent-config-origin.test.ts`, `apps/server/tests/security-invariants.test.ts`	Choose values appropriate to the authorization boundary and verify them at deployment. In Azure Government or other national clouds, set PAPYRUS_AZURE_MANAGEMENT_ENDPOINT, PAPYRUS_AZURE_MANAGEMENT_RESOURCE, PAPYRUS_AZURE_KEYVAULT_DNS_SUFFIX and PAPYRUS_AZURE_KEYVAULT_RESOURCE; they default to Azure commercial endpoints and are not derived from PAPYRUS_ENTRA_CLOUD.
CM-7 Least Functionality	IMPLEMENTED shared	The runtime image contains no browser engine. The Papyrus agent has no general shell: native programs run only through structured executors (Python, Pandoc, LibreOffice) with fixed executables. MCP has no stdio transport. The public scheduler CRUD surface is not exposed, and removed legacy connectors read back as retired and cannot be activated or executed. Evidence: `Dockerfile`, `apps/server/src/agent/mastra/workspace-executors.ts`, `apps/server/src/agent/mcp/servers.ts`, `apps/server/src/agent/database.ts` Tests: `apps/server/tests/agent-image-and-catalog.test.ts`, `apps/server/tests/agent-workspace.test.ts`, `apps/server/tests/agent-mcp-stores.test.ts`, `apps/server/tests/agent-http.test.ts`	Expose only ports 80/443 (and SSH if needed), and disable integrations and model endpoints the organization does not use.
CM-8 System Component Inventory	PARTIAL shared	A generator produces an SPDX 2.3 SBOM of every package in the pnpm lockfile, checked for drift by the pre-commit hook, and the container workflow generates a CycloneDX SBOM of the built image. Evidence: `scripts/compliance/generate.mjs`, `compliance/sbom.spdx.json`, `.github/workflows/container.yml`	Inventory the host OS, container runtime, reverse proxy, model endpoints and other infrastructure in the boundary.
CM-14 Signed Components	PARTIAL shared	Release images are signed with Cosign keyless signing in GitHub Actions. On the Azure Marketplace appliance the updater runs cosign verify against a pinned signer identity and issuer before pulling an update and installs nothing if verification fails; the Marketplace image pipeline verifies the signature and build provenance of the container digest before baking it. Evidence: `deploy/marketplace/vm/papyrus-update.sh`, `deploy/marketplace/vm/provision.sh`, `.github/workflows/marketplace-vm-image.yml`, `.github/workflows/container.yml`, `deploy/azure/main.bicep` Tests: `apps/server/tests/agent-updates.test.ts`	On self-hosted deployments, verify the image signature and digest before deployment.

CONTINGENCY PLANNING

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
CP-9 System Backup	CUSTOMER customer	Papyrus keeps its state in the data directory (agent.db, mastra.db, jobs.db, observability.db, secrets.db and AgentFS) and documents which files must be backed up together and that the local master key must be backed up separately. It provides no backup tooling. Evidence: `docs/deployment.md`	Back up the data directory consistently, store the master key and Key Vault recovery separately, and test restoration.

IDENTIFICATION AND AUTHENTICATION

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
IA-2 Identification and Authentication (Organizational Users)	IMPLEMENTED shared	People authenticate only through the organization's OpenID Connect provider or Microsoft Entra ID. Before sign-in starts, a configured system use notice must be acknowledged. Sign-in uses the authorization code flow with PKCE (S256), single-use state and a nonce; ID tokens are verified against the provider's published keys for issuer, audience, expiry and nonce. Multi-factor and PIV/CAC requirements are enforced by the identity provider, not by Papyrus. Evidence: `apps/server/src/agent/auth.ts` Tests: `apps/server/tests/agent-auth-profile.test.ts`, `apps/server/tests/agent-api-keys-http.test.ts`	Require MFA or phishing-resistant authentication through Entra Conditional Access.

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
IA-4 Identifier Management	IMPLEMENTED shared	Papyrus identifies people by Entra object ID and tenant ID and creates no identifiers of its own for people. API keys receive a random 12-hex-character identifier, and each deployment has its own deployment ID. Evidence: `apps/server/src/agent/auth.ts`, `apps/server/src/agent/api-keys.ts` Tests: `apps/server/tests/agent-auth.test.ts`	Manage identifier issuance and reuse policy in Entra ID.
IA-5 Authenticator Management	IMPLEMENTED shared	API key secrets are 32 random bytes, shown once with cache-control no-store, and stored only as an HMAC-SHA-256 keyed with the deployment secret, so a copied database cannot be used to call the API. Keys expire, can be rotated (the old secret stops immediately) and revoked. Integration settings reject inline passwords, tokens and keys and store only credential references, and model API keys are accepted only over HTTPS from the portal origin. The pre-commit hook scans staged changes for private keys and common token formats. Evidence: `apps/server/src/agent/api-keys.ts`, `apps/server/src/agent/service.ts`, `apps/server/src/agent/http.ts`, `scripts/hooks/secret-scan.mjs` Tests: `apps/server/tests/api-keys.test.ts`, `apps/server/tests/agent-integrations.test.ts`	Manage Entra authenticators (MFA methods, certificates, client secrets) and rotate API keys on the organization's schedule.
IA-8 Identification and Authentication (Non-Organizational Users)	IMPLEMENTED shared	Only tokens issued for the bound Entra tenant are accepted, so any external person must exist in that tenant (for example as a guest). The only unauthenticated route for other systems is a workflow webhook (/hooks/<id>): it answers only for a published workflow with a webhook trigger, requires a signature made with the server-generated secret, and only starts that workflow with the event as its input. Evidence: `apps/server/src/agent/auth.ts`, `apps/server/src/agent/workflow-webhooks.ts` Tests: `apps/server/tests/agent-workflow-webhook-http.test.ts`	Decide whether guests may be assigned Papyrus roles, and which workflows other systems may start by webhook.

INCIDENT RESPONSE

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
IR-4 Incident Handling	CUSTOMER customer	Papyrus provides no incident handling capability or plan. Its audit and observability records are inputs to the deploying organization's process.	Maintain and exercise an incident response plan covering the Papyrus deployment, including revoking roles, API keys and connector credentials and preserving audit databases.

RISK ASSESSMENT

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
RA-5 Vulnerability Monitoring and Scanning	PARTIAL shared	CI scans each built image against the DISA STIG SCAP profile for Amazon Linux 2023, and the published evidence pack includes Trivy vulnerability scans of every platform of the released image. Dependency and static-analysis scanning do not run in CI. Evidence: `.github/workflows/container.yml`	Scan hosts, the deployed image and surrounding infrastructure with the organization's tools.

SYSTEM AND SERVICES ACQUISITION

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
SA-9 External System Services	IMPLEMENTED shared	Papyrus calls no Beag Labs service: licenses are verified locally against keys built into Papyrus, sign-in uses the organization's own identity provider, and the Terms and Privacy Policy ship inside the app. Sentry error reporting is off unless a DSN is set and runs with sendDefaultPii disabled. Evidence: `apps/server/src/license.ts`, `apps/server/src/agent/sentry.ts` Tests: `apps/server/tests/agent-license-authorities.test.ts`	Assess the configured model gateway, MCP servers and any Sentry DSN as external services.

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
SA-11 Developer Testing and Evaluation	PARTIAL provider	The repository has workspace-wide TypeScript type checking and a Vitest suite for the server covering identity, authorization, MCP, secrets, sandboxing and approvals. CI runs type checking and a fixed subset of tests (scoped workflows, mainframe guardrails, policies, execution records, channel linking and offline evaluations), and a local pre-commit hook runs secret, contract and compliance-drift checks plus security-invariant tests when related files change. Evidence: `.github/workflows/ci.yml`, `scripts/hooks/precommit.mjs`, `apps/server/tests/security-invariants.test.ts`	

SYSTEM AND COMMUNICATIONS PROTECTION

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
SC-4 Information in Shared System Resources	PARTIAL provider	Papyrus databases are opened with SQLite secure_delete, so content removed from them is overwritten rather than left in free pages. Each agent workspace runs in its own sandboxed process with a temporary materialized workspace. Evidence: `apps/server/src/agent/database.ts`, `apps/server/src/agent/mastra/runtime.ts`	Use volume encryption and sanitize media under the organization's procedures.
SC-5 Denial-of-Service Protection	PARTIAL shared	Request bodies are read under fixed byte ceilings and refused with 413 beyond them; workflow webhooks are rate-limited per webhook and take bodies of at most 1 MB; pending sign-ins are capped; and outbound workflow requests time out after 15 seconds with bodies limited to 256 KiB. Evidence: `apps/server/src/agent/http.ts`, `apps/server/src/agent/rate-limit.ts`, `apps/server/src/agent/workflow-webhooks.ts` Tests: `apps/server/tests/agent-http.test.ts`	Provide network-layer DoS protection and rate limiting at the reverse proxy or gateway.
SC-7 Boundary Protection	PARTIAL shared	Workflow HTTP steps, link previews, MCP servers and repository imports pass one egress gate: HTTPS, no embedded credentials, refusal of hosts that resolve to loopback, private or link-local addresses unless listed as internal, and, when egress.allowedHosts is set (required on the disconnected profile), only listed hosts. Redirects are re-checked hop by hop. Workspace commands have no network access. On the Marketplace appliance the container is published only on 127.0.0.1 behind nginx. Evidence: `apps/server/src/agent/mastra/workflow-runtime-tools.ts`, `apps/server/src/agent/mcp/oauth.ts`, `deploy/marketplace/vm/provision.sh`, `apps/server/src/agent/azure-key-vault.ts` Tests: `apps/server/tests/workflow-http-target.test.ts`, `apps/server/tests/agent-mcp-stores.test.ts`	Place the deployment behind the organization's firewalls and proxies, restrict inbound access to 443, and set the egress denylist and internal-host list.
SC-8 Transmission Confidentiality and Integrity	IMPLEMENTED shared	Persistent mode refuses to start without an HTTPS public origin. The daemon can terminate TLS itself with a TLS 1.2 minimum, and the Marketplace appliance's nginx edge allows only TLS 1.2 and 1.3 and sends HSTS. Portal cookies are Secure under HTTPS. Outbound connections to MCP servers, workflows and imported APIs require HTTPS except for hosts the organization explicitly lists as internal. Evidence: `apps/server/src/agent/config.ts`, `apps/server/src/agent/http.ts`, `deploy/marketplace/vm/provision.sh` Tests: `apps/server/tests/workflow-http-target.test.ts`	Provide certificates, TLS termination and cipher policy that meet organizational requirements.
SC-12 Cryptographic Key Establishment and Management	PARTIAL shared	The local secrets master key must be a separately provisioned 32-byte file that is not group- or world-writable and is opened without following symlinks; the server never generates it. Where Azure Key Vault is configured, the portal secret, Entra client secret and model and provider keys are kept in a deployment Key Vault (RBAC mode, purge protection, 90-day soft delete) with only the VM's managed identity granted access, and each reader is limited to its own secret-name prefix. License authority public keys are supplied by configuration or baked into the DoD image. Evidence: `apps/server/src/agent/local-secrets.ts`, `apps/server/src/agent/deployment-vault.ts`, `apps/server/src/agent/azure-key-vault.ts`, `apps/server/src/agent/openapi/credentials.ts` Tests: `apps/server/tests/agent-local-secrets.test.ts`, `apps/server/tests/agent-deployment-vault.test.ts`	Provision, back up and protect the master key and portal secret; manage Entra and TLS keys.

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
SC-13 Cryptographic Protection	IMPLEMENTED shared	The image runs OpenSSL with Amazon Linux 2023's certified FIPS 140-3 provider (CMVP #5438) forced on, and Papyrus refuses to start if FIPS mode is not active or MD5 is still allowed. Stored credentials use AES-256-GCM; cookies, API key hashes and webhook signatures use HMAC-SHA-256; hash chains use SHA-256. Evidence: `apps/server/src/fips-check.ts` , `Dockerfile`	Where FIPS 140 validated cryptography is required, run on a validated module and terminate TLS on validated infrastructure.
SC-18 Mobile Code	IMPLEMENTED provider	Papyrus runs no agent-built code in the browser. HTML and SVG artifacts are served as attachments with a sandbox CSP (default-src 'none'), so they cannot run in the portal's origin. Evidence: `apps/server/src/agent/http.ts` Tests: `apps/server/tests/agent-artifact-content-http.test.ts`	
SC-23 Session Authenticity	IMPLEMENTED provider	The portal session cookie is HMAC-SHA-256 signed with the deployment secret, compared in constant time, and set HttpOnly, SameSite=Strict, Secure and with the __Host- prefix under HTTPS. OIDC state and nonce are random 32-byte values held server-side, single-use and expiring after 10 minutes; MCP OAuth sign-ins are likewise single-use, bound to the initiating person and checked against the discovered issuer. Once an HTTPS origin is configured, request headers cannot change the origin used for redirects or cookies. Evidence: `apps/server/src/agent/auth.ts` , `apps/server/src/agent/mcp/oauth.ts` , `apps/server/src/agent/config.ts` Tests: `apps/server/tests/agent-mcp-runtime.test.ts` , `apps/server/tests/agent-config-origin.test.ts` , `apps/server/tests/agent-auth-profile.test.ts`	
SC-28 Protection of Information at Rest	PARTIAL shared	Papyrus encrypts secrets at the application layer with AES-256-GCM and per-record associated data: model gateway keys in a separate 0600 secrets database under a separately provisioned master key; and connector, imported-API and MCP credentials bound to their owner. Where Azure Key Vault is configured, platform secrets are stored there and configuration files hold only references. SQLite databases are opened with secure_delete, so deleted rows are overwritten rather than left in free pages. Evidence: `apps/server/src/agent/local-secrets.ts` , `apps/server/src/agent/openapi/credentials.ts` , `apps/server/src/agent/deployment-vault.ts` Tests: `apps/server/tests/agent-local-secrets.test.ts` , `apps/server/tests/agent-mcp-stores.test.ts` , `apps/server/tests/agent-deployment-vault.test.ts`	Encrypt the volume that holds the data directory and its backups, and manage those keys.
SC-39 Process Isolation	IMPLEMENTED provider	Commands the Papyrus agent runs in its workspace run in a separate worker process under landstrip (Landlock and seccomp on Linux, Seatbelt on macOS) with writes limited to a temporary materialized workspace, the Papyrus data directory unreadable and network denied. The worker validates and resolves the effective policy before starting the command and refuses to run if the write root, network restriction or data-directory denial is not in effect; unsupported platforms run no workspace commands. Credential-like environment variables are removed before the command starts. Evidence: `apps/server/src/agent/mastra/workspace-nono-worker.ts` , `apps/server/src/agent/mastra/workspace-nono.ts` , `apps/server/src/agent/mastra/workspace-landstrip.ts` Tests: `apps/server/tests/security-invariants.test.ts` , `apps/server/tests/agent-workspace.test.ts` , `apps/server/tests/agent-session-workspace.test.ts`	Run on a Linux host with Landlock enabled and do not run the container privileged.

SYSTEM AND INFORMATION INTEGRITY

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
SI-2 Flaw Remediation	PARTIAL shared	Beag Labs publishes fixes as new signed images. A deployment learns of a release through an HMAC-signed, timestamped webhook with replay protection, and a System Owner applies it or allows it to apply within a maintenance window; the Marketplace updater verifies the image signature before installing. Evidence: `apps/server/src/agent/updates/service.ts`, `deploy/marketplace/vm/papyrus-update.sh` Tests: `apps/server/tests/agent-updates.test.ts`	Set patch windows, test updates and apply them within organizational timeframes.
SI-4 System Monitoring	IMPLEMENTED shared	Papyrus records agent traces and logs in a separate observability database readable by System Owners, Audit Viewers and Security Managers, writes structured JSON warnings to standard output, and can send errors to a customer-supplied Sentry DSN. Security events are written to the unified audit trail and exported to the organization's collector over OTLP when configured. The container health check verifies that the landstrip sandbox enforces its boundary; it does not check that the HTTP service is answering. Evidence: `apps/server/src/agent/http.ts`, `apps/server/src/agent/sentry.ts`, `Dockerfile`, `deploy/container/healthcheck.mjs` Tests: `apps/server/tests/agent-observability.test.ts`	Collect container output and audit data into the organization's monitoring platform and alert on it.
SI-7 Software, Firmware, and Information Integrity	IMPLEMENTED shared	Releases are referenced by image digest and signature-verified before the Marketplace updater installs them. Governed changes are re-hashed at approval and refused if the digest differs. Integration and action events are hash-chained. Evidence: `apps/server/src/agent/updates/service.ts`, `apps/server/src/agent/policies/store.ts` Tests: `apps/server/tests/agent-policies.test.ts`	Verify image digests and signatures on deployment paths other than the Marketplace appliance.
SI-10 Information Input Validation	IMPLEMENTED provider	Request bodies must be JSON objects under per-route byte limits; required strings are length-bounded; policy rules are validated against a fixed schema; outbound addresses are validated before use; and workflow webhook payloads are signature-checked over the exact raw bytes before they are parsed. Evidence: `apps/server/src/agent/http.ts`, `apps/server/src/agent/policies/evaluator.ts`, `apps/server/src/agent/workflow-webhooks.ts` Tests: `apps/server/tests/agent-policies.test.ts`, `apps/server/tests/agent-http.test.ts`	
SI-11 Error Handling	PARTIAL shared	Errors are returned as JSON with a code and a per-request ID. Known error types map to specific status codes, sign-in error pages do not echo request input, the browser connection address is masked in error text, and imported-API credentials are redacted from errors. Evidence: `apps/server/src/agent/http.ts` Tests: `apps/server/tests/agent-mcp-http.test.ts`	Configure log handling so diagnostic output is not exposed beyond administrators.

SUPPLY CHAIN RISK MANAGEMENT

CONTROL	STATUS	PAPYRUS IMPLEMENTATION	DEPLOYING ORGANIZATION
SR-4 Provenance	PARTIAL shared	Container images built from main are signed with Cosign and receive a GitHub build provenance attestation. Dependencies are locked in pnpm-lock.yaml and installed with --frozen-lockfile in CI, and the pnpm version is pinned with a hash in packageManager. Evidence: `.github/workflows/container.yml`, `pnpm-lock.yaml`, `package.json`, `.github/workflows/ci.yml`	Retain the image digests and attestations for deployed releases and verify them at intake.